

1. Systeme Firewall



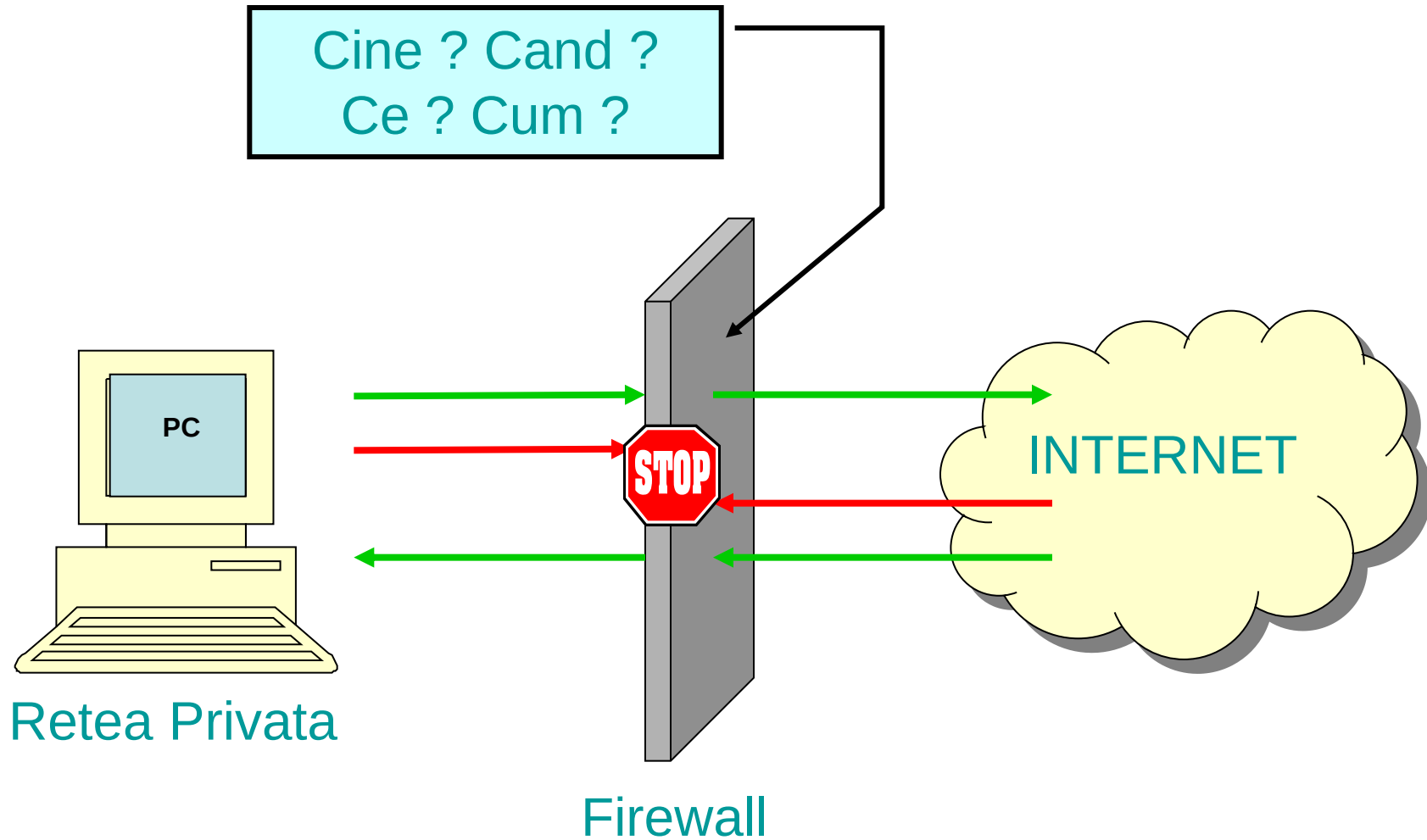
Sisteme firewall

- Conectarea la Internet este o cerință de business pentru majoritatea organizațiilor
- Un calculator conectat direct la Internet este o țintă posibilă pentru atacatori
- Orice disfuncționalitate a sistemelor de calcul costă bani (direct sau indirect)
- Sunt necesare mecanisme de protecție a rețelelor interne împotriva atacurilor externe

Rolul unui firewall

- O manifestare fizică a politicii de securitate în rețea
- Punct de control și monitorizare a traficului între două rețele
- Mecanism pentru limitarea accesului la resursele/serviciile din rețeaua internă
- Similar unui “zid de apărare”

Rolul unui firewall (cont.)



Cerințe pe care trebuie să le satisfacă un firewall

- 1. Tot traficul din interior spre exterior și vice versa trebuie să treacă prin firewall**
 - nu trebuie să existe puncte de acces în rețea necontrolate (backdoors)
- 2. Numai traficul autorizat, stabilit prin politica de securitate internă, poate să treacă prin firewall**
 - reguli de acces stricte
- 3. Firewall-ul însuși trebuie să fie imun la atacuri. Aceasta presupune folosirea unui sistem de încredere care a fost supus în prealabil unui proces de securizare (hardening)**
 - mașini dedicate pe care nu trebuie să mai ruleze alte servicii

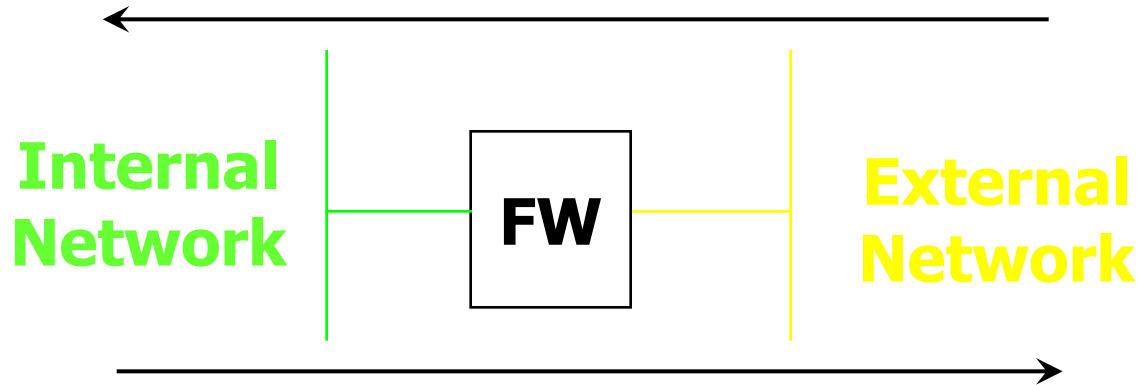
Terminologie

- **Pachet** – unitatea de informație creată de un protocol de rețea pentru a transporta date și informații de control. În contextul stivei TCP/IP se mai numește și datagramă.
- **DMZ (DeMilitarized Zone)** – un segment de rețea dispus între exterior (Internet) și rețeaua internă, având rolul de a intermedia schimbul de informații. Este rețeaua în care, de regula, sunt dispuse serviciile publice (Web, Mail, DNS, etc).
- Rețele protejate și neprotejate
 - **Rețelele protejate** sunt localizate în spatele unui firewall, fiind protejate prin politicile acestuia
 - **Rețelele neprotejate**, cum ar fi Internet-ul, stau în fața unui firewall și nu sunt protejate de către politicile acestuia
- Direcții ale traficului
 - **Inbound** = spre interiorul zonei protejate de firewall
 - **Outbound** = spre exteriorul zonei protejate de firewall

Terminologie (cont.)

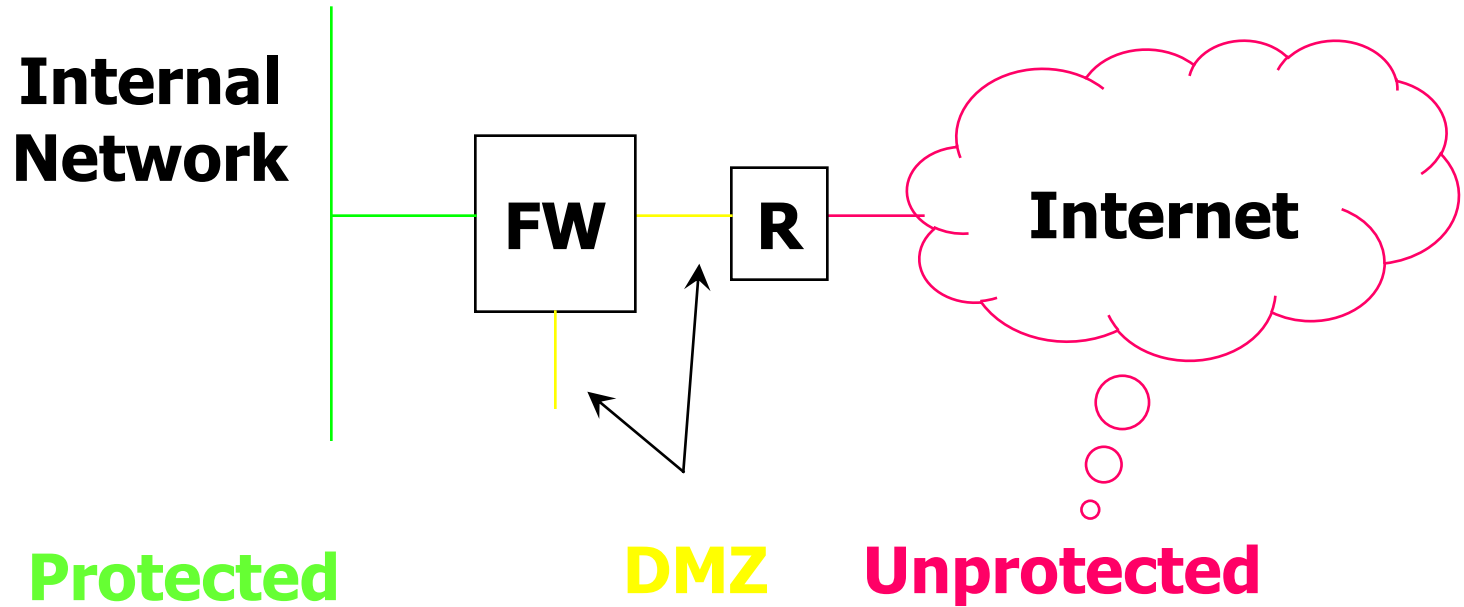
- **Inbound vs. Outbound**

- **Inbound** = spre interiorul zonei protejate de firewall

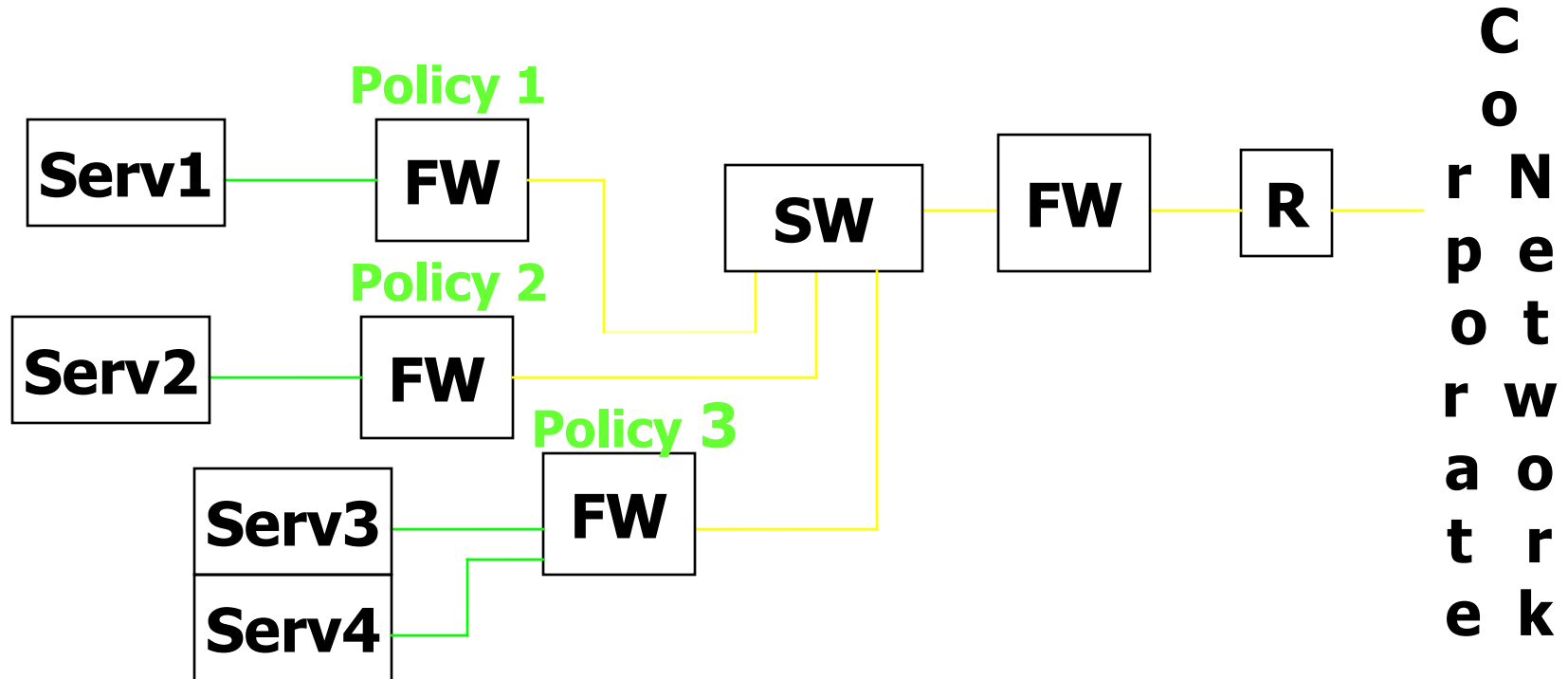


- **Outbound** = spre exteriorul zonei protejate de firewall

Exemplu de firewall



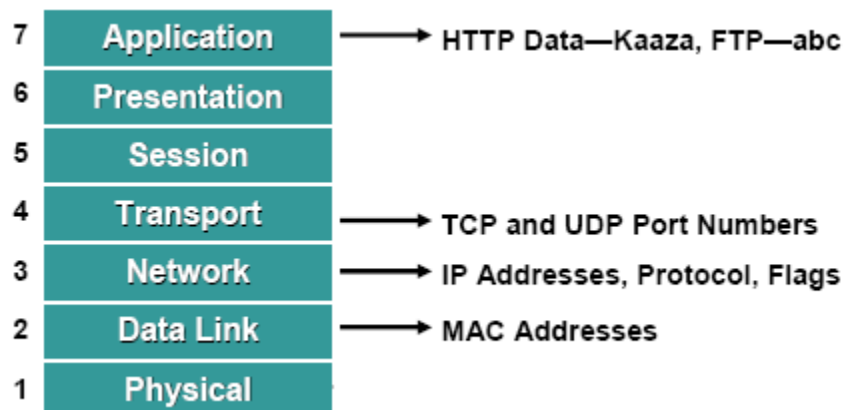
Exemplu de firewall (cont.)



Politici de firewall

- **Pe bază de blacklist-uri (default-allow)**
 - toate pachetele sunt permise, cu excepția celor care se încadrează în regulile de filtrare și care sunt respinse
 - flexibilitate mare
 - pot exista cazuri în care traficul malițios trece prin firewall
- **Pe baza de whitelist-uri (default-deny)**
 - toate pachetele sunt respinse, cu excepția celor care sunt permise explicit prin regulile de filtrare
 - trebuie definită câte o regulă pentru fiecare tip de trafic
 - abordare mai sigură

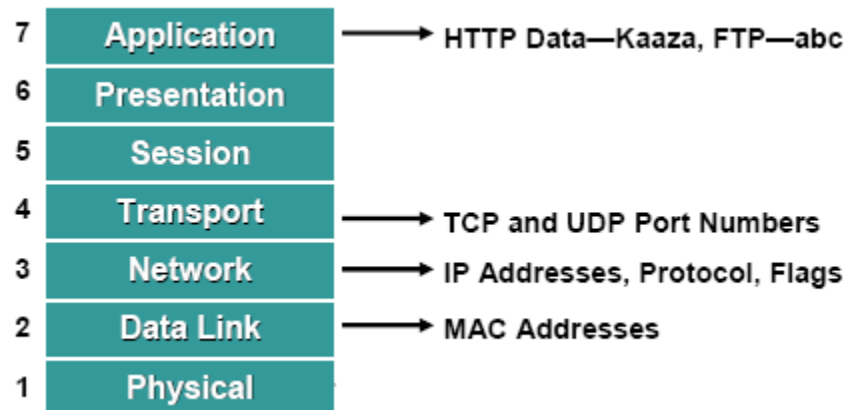
Parametri de control al accesului



Exemple de politici (reguli):

- La nivel legătură de date
 - Interzice toate pachetele de la adresa MAC 00-1c-bf-01-02-03
 - Nu cere autentificarea dacă adresa MAC este 00-1c-2b-aa-bb-cc
- La nivel rețea
 - Interzice orice trafic, cu excepția pachetelor de ieșire ce vin de la rețeaua 10.10.10.0/24
 - Permite numai trafic ESP (IPsec)
 - Interzice orice trafic, cu excepția traficului de la rețeaua 172.16.30.0/24, spre rețeaua 192.168.10.0/24

Parametri de control al accesului (cont.)



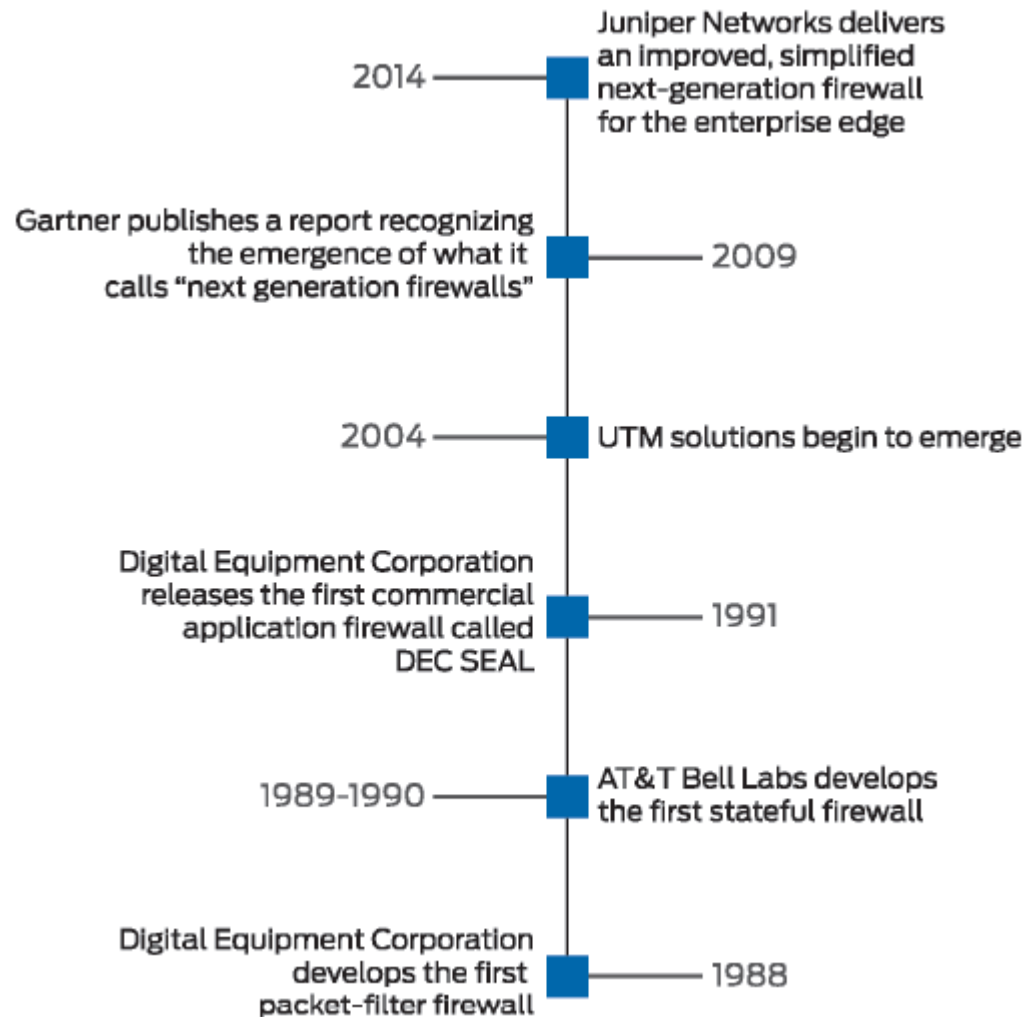
Exemple de politici (reguli):

- **La nivel transport**
 - Permite traficul de Web de oriunde (inclusiv Internet), cu condiția ca adresa destinație să fie a serverului propriu – 192.168.0.10
 - Permite traficul FTP de oriunde spre propriul server – 192.168.0.11
- **La nivel aplicație**
 - Nu permite trafic HTTP în al cărui header există comanda “POST”
 - Nu permite opțiunea “DEBUG” în comenzile SMTP (e-mail)

Tipuri de firewall

- **Packet Filtering Firewall**
 - **Stateful Inspection Firewall**
 - **Proxy Firewall**
 - **Next-Generation Firewall (NGFW)**
-
- **Network-Based Firewall**
 - **Host-Based Firewall**

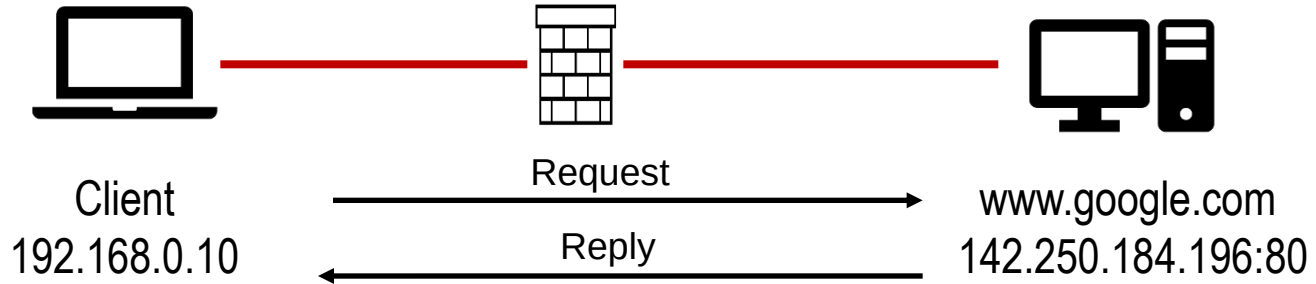
Cronologia firewall



Packet Filtering Firewall

- Permite sau interzice pachetele funcție de adresă sau port
 - reguli de filtrare (ACL – Access Control List): *deny / allow*
 - regula default: *deny all*
- Verificarea pachetelor se face în ambele direcții (*inbound* respectiv *outbound* trafic)
- Payload-ul pachetelor (zona de date) nu este inspectat
- Nu memorează informații de stare
 - pachetele sunt tratate individual, fără a ține cont de context
- Funcție suportată de majoritatea ruterele actuale
- Avantaje
 - simplu, rapid, transparent pentru utilizatori
- Dezavantaje
 - nu poate bloca toate tipurile de trafic
 - inefficient împotriva atacurilor care exploatează vulnerabilități ale protocoalelor din stiva TCP/IP
 - eficiență scăzută în cazul fragmentării pachetelor

Packet Filtering Firewall (cont.)



- **Sunt necesare două reguli pentru a permite traficul între client și server:**
 1. `tcp ip src 192.168.0.10 ip dst 142.250.184.196 port dst 80 allow`
 2. `tcp ip src 142.250.184.196 port src 80 ip dst 192.268.0.10 allow`

Stateful Inspection Firewall

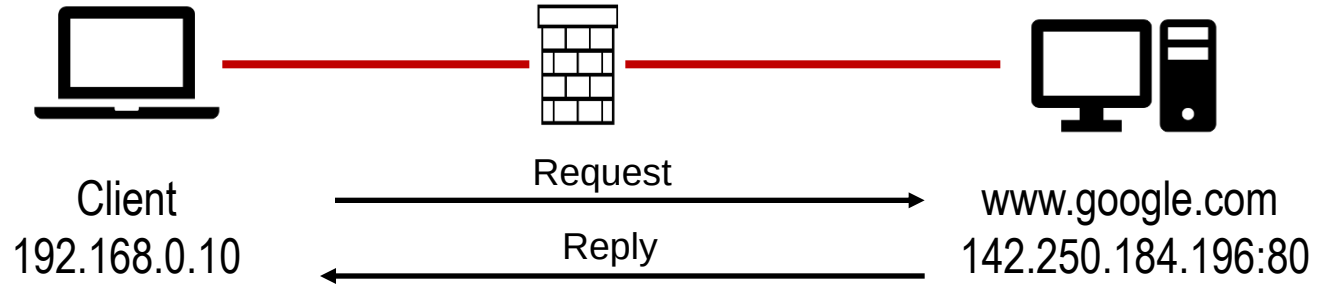
- Bazat tot pe filtrarea de pachete
- Inspectează pachetele și memorează informații de stare pentru fiecare conexiune în parte
 - odată ce un pachet este identificat ca făcând parte dintr-o conexiune stabilită, procesarea acestuia poate fi optimizată (lua o cale mai scurtă)
 - informația de stare ce se memorează diferă de la producător la producător
- Eficiență crescută în blocarea atacurilor

Stateful Inspection Firewall (cont.)

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	192.0.2.71	80	Initiated
192.168.1.102	1031	10.12.18.74	80	Established
192.168.1.101	1033	10.66.32.122	25	Established
192.168.1.106	1035	10.231.32.12	79	Established

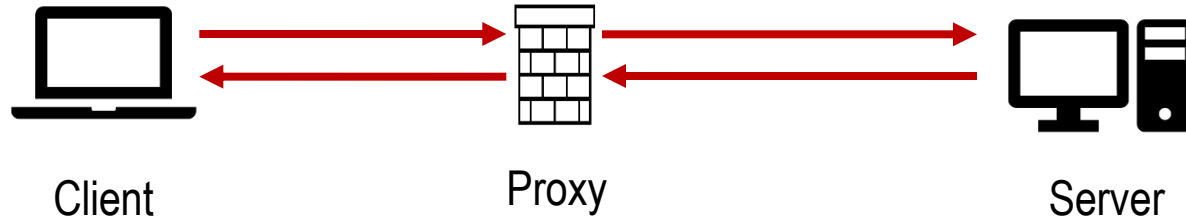
- Fiecare pachet primit este analizat în conformitate cu conținutul tabelii de stare:
 - dacă starea pachetului corespunde stării din tabel, atunci pachetul este lăsat să treacă
- Mașini de stare pentru fiecare protocol (TCP, UDP, etc)
 - blocarea pachetelor care nu aderă strict la starea mașinii din momentul respectiv (de exemplu, numărul de secvență TCP este în afara ordinii)
- Ce se întâmplă în cazul protocoalelor de tip connectionless (UDP)?
 - se urmărește doar adresele și porturile sursă și destinație
 - un răspuns DNS va fi lăsat să treacă numai dacă a existat în prealabil o interogare DNS
 - intrările din tabelă sunt șterse automat după un interval de timp

Stateful Inspection Firewall (cont.)



- Este suficientă o singură regulă pentru a permite traficul între client și server :
 1. `tcp ip src 192.168.0.10 ip dst 142.250.184.196 port dst 80 allow`

Proxy Firewall



- Un proxy firewall acționează ca un intermediar între client și server
 - două conexiuni separate: client-proxy, proxy-server
 - toate cererile și răspunsurile trec prin proxy unde sunt validate
- Inspectează și filtrează traficul la nivel aplicație
- Caching pentru creșterea performanței
- Forward Proxy
 - protejează clienții interni prin medierea traficului de ieșire
 - Squid
- Reverse Proxy
 - protejează serverele interne prin medierea traficului de intrare
 - Nginx, HAProxy
- Transparent Proxy
 - interceptează traficul fără a necesita configurări la nivel de client
 - nu modifică cererile clienților
- Application Layer Proxy
 - deep packet inspection și content filtering

Web Application Firewall

- **Asigură protecția aplicațiilor Web prin monitorizarea și filtrarea traficului HTTP/S**
 - SQL injection, XSS, CSRF, etc.
- **Operează ca și un reverse proxy**
- **Network-Based WAF**
- **Host-Based WAF**
- **Exemple de produse:**
 - F5 Advanced WAF
 - Imperva WAF
 - Modsecurity (open source)

Next-Generation Firewall (NGFW)

- Cel mai performant tip de firewall
- Integrează funcții tradiționale de firewall cu caracteristici suplimentare de securitate
 - Application Control
 - Intrusion Prevention System (IPS)
 - Deep Packet Inspection (DPI)
 - Threat Intelligence
 - SSL/TLS Inspection
 - Sandboxing
- Necesită plata unui abonament pentru a putea detecta cele mai recente tipuri de atacuri!

Alte tehnologii

- **Network Access Control (NAC) / Network Acces Protection (NAP)**
 - verificarea calculatoarelor utilizatorilor înainte de a le da accesul în rețeaua internă
 - calculatorul este pus inițial într-o "zonă de carantină" (rețea specială), verificat din punct de vedere al securității (antivirus, update-uri, etc) și apoi i se permite accesul în rețeaua internă

- **Unified Threat Management (UTM)**
 - implementarea mai multor funcționalități de securitate pe un singur echipament (firewall, IDS, antivirus, VPN)
 - reduce efortul de administrare
 - limitări din punct de vedere al performanței

Caracteristici cheie pentru un firewall

- **Hardware vs. software firewall**
 - appliance cu sistem de operare specializat
 - mașină fizică sau virtuală cu sistem de operare de uz general
- **Performanța**
 - viteza de procesare (bps, pps, cps)
 - scalabilitatea
- **Politici de filtrare suportate**
 - pe bază de adrese și protocoale
 - funcție de aplicațiile de rețea utilizate
 - pe baza identității utilizatorilor
- **Disponibilitatea**
 - activ-pasiv
 - activ-activ
- **Integrarea cu infrastructura existentă**
 - cu serviciile de autentificare (Radius, Tacacs+)
 - cu serviciile de logging și monitorizare
- **Management**
 - SSH, HTTPS

Limitările unui firewall

- **Nu asigură protecție împotriva atacurilor interne**
 - 70 % din atacuri sunt din interior!
- **Protecție limitată împotriva zero-day attacks**
 - se bazează pe reguli și semnături predefinite pentru a detecta atacuri
- **Nu pot inspecta traficul criptat / tunelat**
- **Nu pot bloca atacuri de tip phishing sau link-uri malițioase**
- **Sisteme complexe**
 - configurarea și administrarea unui firewall nu este simplă!

Produce firewall

- **Linux netfilter/iptables**
- **Linux pfSense**
- **Palo Alto Networks PA/VM**
- **Fortinet FortiGate**
- **Check Point FireWall-1**
- **Cisco Firepower**
- **Juniper NetScreen**

Gartner Magic Quadrant for Enterprise Network Firewalls

Figure 1: Magic Quadrant for Network Firewalls



Source: Gartner (December 2022)

